

Lab 09 – Regulatory Gap Analysis

Industrial Security (Bachelor)

• Maps to Section 09

• 60 min

LAB 09**🎯 Goal**

For a fictional mid-sized German water utility, identify the applicable laws and standards, score five obligations against the controls covered in this course, and recommend three concrete improvements.

✂ Step 1 – Map the regulatory surface

List the German and EU obligations that apply to a 600-thousand-customer water utility. Include:

- EU NIS2 – Directive (EU) 2022/2555 (essential entity status; transposition deadline was 17 Oct 2024).
- KRITIS – BSI-Kritisverordnung + the NIS2 transposition law (NIS2UmsuCG), superseding IT-SiG 2.0.
- B3S Wasser/Abwasser – the recognised sectoral standard published under §8a BSIG.
- Cross-cutting: DSGVO (GDPR) for personal data; EU CRA – Regulation (EU) 2024/2847 – for any connected product the utility procures.

✂ Step 2 – Pick five obligations

Choose five concrete obligations (e.g. “attack detection capability”, “incident notification within 24 hours”) and assess current compliance: *compliant* / *partial* / *non-compliant* with one-line justification each.

✂ Step 3 – Map to IEC 62443 and CSF

For each obligation, cite the matching IEC 62443 system requirement (SR) and the matching NIST CSF subcategory.

✂ Step 4 – Recommend improvements

Propose three concrete improvements with: *rough cost*, *time horizon*, *owner*.

📁 Deliverable

Hand in: a 1-page gap-analysis table (Obligation, Status, 62443 SR, CSF, Action) plus the three recommendations.